Fix: Next.js security upgrade

Type: Fix

Size: light - one dependency moved to its patched release, no code change; proved by the builds, the suites and a walk through the dashboard.

Status: verified

Branch: fix/next-security-upgrade

The problem

On 2026-10-25 `npm audit --workspace=frontend` reported a critical advisory set against `next` 16.3.5, the version the live dashboard (app.booking-crm.com, on Vercel) runs: unauthenticated remote code execution in the Image Optimization API when SVG files are used and in `use cache` functions returning typed arrays (both up to 16.4.0), cache poisoning, request forgery in image optimization, and a Server Actions denial of service. The frontend uses neither `next/image`, `use cache` nor `next/og`, so the worst paths need parts it does not use, but the image optimization endpoint answers on every Next.js site by default. Frank's yes to upgrade, 2026-10-25.

- `frontend/package.json`, `package-lock.json`

The fix

Move `next` from 16.3.5 to 16.4.3, the first release past every advisory, and `eslint-config-next` with it (they ship together). Same major version: no code change is expected; if the build asks for one, it is made and named. Nothing else is upgraded here: the other high warnings in the audit (zod, undici, body-parser, sharp, vite and others, across the workspaces) are a separate point.

It must not break: the dashboard's pages, sign-in, the customer's booking page and its headers (`next.config.ts`), and the booking window's build.

Build steps

- [x] 1. **Next.js 16.4.3. Done when:** `npm audit --workspace=frontend` lists no `next` advisory; the frontend and backend build, lint and every suite pass; and on http://localhost:3400 sign-in, Leads, the Calendar, Settings (People and Services, one Save each) and a customer booking page at `/b/<token>` load with no console errors.

Verify

Open app.booking-crm.com after the deploy: sign in, open Leads, the Calendar and Settings. Vercel's build log shows Next.js 16.4.3.

Implementation walkthrough

One step, as the spec planned (light), and one review round with nothing found. Found on 2026-10-25 when the Agent app's build stopped on the same advisory; `npm audit` showed the live dashboard's Next.js 16.3.5 inside it too.

frontend/package.json and the lockfile

`next` and `eslint-config-next` move from 16.3.5 to 16.4.3, pinned exact as before, installed with `npm install --workspace=frontend next@16.4.3 eslint-config-next@16.4.3 --save-exact`. The lockfile moves only what that pulls in: `@next/env`, `@next/eslint-plugin-next` and the `@next/swc-*` binaries to 16.4.3, and `sharp` to 0.35.5 (Next 16.4.3 asks for `^0.35.5`, which also clears the `sharp` librsvg warning). The local `packages/booking-component` entry caught up to the 0.2.0 its `package.json` already had. `better-auth` and `@imagekit/next` share the one `next` entry. npm now holds back install scripts it has not been told to trust (esbuild, unrs-resolver); the builds pass without them, as their binaries come from their own platform packages.

no code change

Next.js 16.4 only adds (`ensureStatic`, `navigation` and `prefetch` out of `unstable_`, new experimental options, ESLint 10 support); the frontend uses none of what changed, and `next.config.ts` keeps its rewrite and the booking page's three headers as they were.

what is left

`npm audit --workspace=frontend` now shows no critical; 7 high and 9 moderate remain in other packages (zod, undici, body-parser, vite, shadcn, @modelcontextprotocol/sdk, source-map-js and others), a separate point.

Findings

None: the independent review found nothing, and no carried finding was resolved here.

Independent review

Status: passed **Target commit:** 7fbfe20b4ae9406f18002b88d78c100c82fbc057 **Base commit:** c2909d20e4e8ffa661da89b146f648920ba6e406 **Base ref:** main **Spec hash:** 35d0894cb73d5311b244417b9b80cd95c3b45f6b9847bf650cd0a9ac8f8d0723 **Prepared by:** claude

Builder model: claude-opus-5-5 **Requested reviewer:** claude **Requested model:** claude-opus-5-5 **Requested execution:** automatic **Requested at:** 2026-10-25T17:31:16Z **Workflow:** regular **Check required:** no **Reviewer adapter:** claude **Reviewer model:** claude-opus-5-5 **Reviewer context:** fresh subagent **Actual execution:** automatic **Reviewed at:** 2026-10-25T17:36:58Z **Scope:** current **Lenses:** quality, security, performance, tests **Verdict:** passed **Check result:** not-required

Commands

- `npm run test --workspace=@scheduleads-app/shared` : pass (32 files, 214 tests)
- `npm run test --workspace=backend` : pass (95 files, 1098 tests, local Postgres)
- `npm run test --workspace=@frankdmosquera/booking-component` : pass (18 files, 98 tests)
- `npm run build --workspace=backend` : pass
- `npm run build --workspace=frontend` : pass (Next.js 16.4.3, Turbopack)
- `npm run lint --workspace=frontend` : pass
- `npm run format:check` : pass
- `npm audit --workspace=frontend` : pass for this fix (no `next` entry, 0 critical; 7 high and 9 moderate remain in other packages, out of scope per spec)

Evidence

- Freshness: HEAD = target, `git merge-base main HEAD` = base, spec SHA-256 matches, only `review.md` differs from the target.
- Delta is three files: `frontend/package.json` (`next` and `eslint-config-next` 16.3.5 to 16.4.3), `package-lock.json` , and the spec.
- Lockfile: `next` resolves 16.4.3 at its single entry `node_modules/next` (deduped for `better-auth` and `@imagekit/next` per `npm ls next`); installed `node_modules/next` is 16.4.3.
- Other lockfile moves, all pulled by the upgrade or a lock resync: `@next/env` , `@next/eslint-plugin-next` and the eight `@next/swc-` *binaries 16.3.5 to 16.4.3;* `sharp` *and its* `@img/sharp-` binaries 0.35.4 to 0.35.5 and `@img/sharp-libvips-*` 1.3.3 to 1.3.4 (next 16.4.3 raises its optional `sharp` range to `^0.35.5`); `packages/booking-component` 0.1.0 to 0.2.0, a stale lock entry resynced to the version its `package.json` already had at the base. Nothing added or removed.
- Next.js 16.4 docs (`node_modules/next/dist/docs/`): additions only (`ensureStatic` , `navigation` / `prefetch` renamed from `unstable_` *, new experimental Turbopack and agent options,* `eslint-config-next` *ESLint 10 support). The frontend uses no* `unstable_` API, no `next/image` , `use cache` or `next/og` , no proxy/middleware, no `settings.react.version` override; `frontend/next.config.ts` (rewrites, headers) needs no change.
- Running local app at http://localhost:3400/b/review-probe-token still returns `Referrer-Policy: no-referrer` , `Cache-Control: no-store` , `X-Robots-Tag: noindex, nofollow` .

Findings

- None

Remaining risk

- The spec's dashboard walk (sign-in, Leads, Calendar, Settings saves, a real `/b/<token>` page, console errors) was not repeated: the reviewer has no dashboard login. Only the booking page headers were probed.
- The live deploy on Vercel (16.4.3 in its build log) is not verified here; that is the spec's Verify step after merge.
- Remaining high audit warnings (zod, undici, body-parser, vite, shadcn, @modelcontextprotocol/sdk, source-map-js) are a separate point per the spec and stay open.